COMP3052.SEC Computer Security

Session 11: OS Security II: Windows Security

Acknowledgements

- Some of the materials we use this semester may come directly from previous teachers of this module, and other sources ...
- Thank you to (amongst others):
  - Michel Valstar, Milena Radenkovic, Mike Pound, Dave Towey, ...

This Session

- Windows Security
  - Permissions
  - Access Tokens
  - Authentication
- Kerberos

Overview

- The Windows security model has seen a steady evolution
- This lecture is not windows version-specific
- Security in Windows is much more fine-grained than other operating systems

Security Subsystem

- Runs in user mode
- Logon processes (winlogon, LogonUI)
- Local Security Authority (LSA)
  - Checks User Accounts
  - Provides access token
  - Responsible for auditing
- Security Account Manager (SAM)
  - Maintains user account database used by LSA
  - Encrypts / hashes passwords

Windows

- Windows predominantly uses Access Control Lists, and has done since Windows NT
- Extends the usual read, write and execute with:
  - Take ownership
  - Change permissions
  - Delete
- 32-bit access masks (cf. Unix 9-bit)
- A higher degree of control, with the associated complexity increase!

Access Control

- Access control in windows treats more than just files, also:
  - Registry keys
  - Active directory objects
  - Groups
- Inheritance is implemented
  - File can inherit ACLs from parent directories

Microsoft Active Directory

Principals

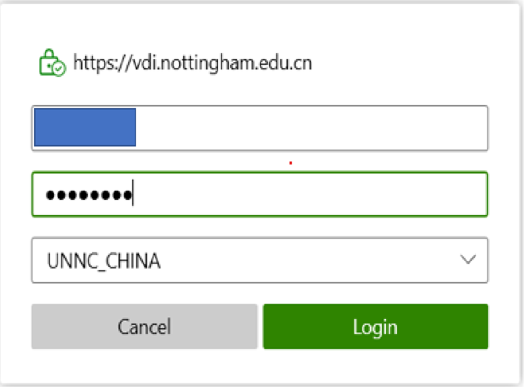
- Principals more broadly defined as well:
  - Local users
  - Domain users
  - Groups
  - Machines
- Each principal has a human-readable name and security ID (SID)

S-1-5-21-2475811070-2421845406-3333283485-1005

S-1-5-21-1664130791-3153540899-3044996548-279530

Local / Domain Principals

- Local Security Authority (LSA) creates local principals
  - principal = MACHINE\principal
    - E.g., Host\Dave
- Domain principals administered on Domain Controller (DC) by domain admins
  - principal@domain = DOMAIN\principal
    - net user / domain
    - net group / domain
    - net localgroup / domain



Groups

- Groups are collections of SIDs
- Group can itself be an SID
- Groups can thus be nested
- Groups are not nest-able on local machines
- Managed by a domain controller with Active Directory

Objects

- Objects are passive entities in access operations
- In Windows:
  - Private objects (files, directories)
  - Executive objects (processes, threads, etc.)
- Securable objects have a security descriptor
  - Private objects managed by application software
  - Built-in securable objects managed by the OS

Owner SID
Primary Group
DACL
SACL

Discretionary Access Control List (DACL)
System Access Control List (SACL)

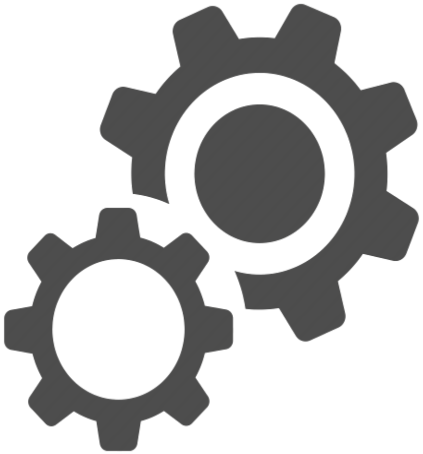
Access Tokens

- Security credentials for a login session stored in access token
- Identifies the user, the user's groups, and the user's privileges

Access Token
User SID
Groups and Alias SID
Privileges
Defaults for New Objects
Miscellaneous

Subjects

- Windows subjects: Processes and threads
- New processes get a copy of the parent access token, possibly modified
- Individual access tokens are immutable, and can live beyond policy changes (TOCTTOU issue)

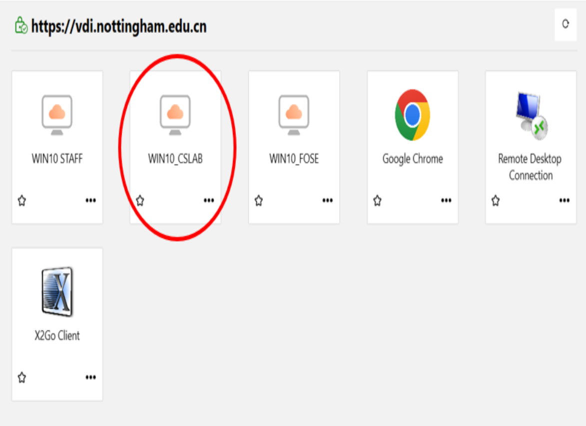


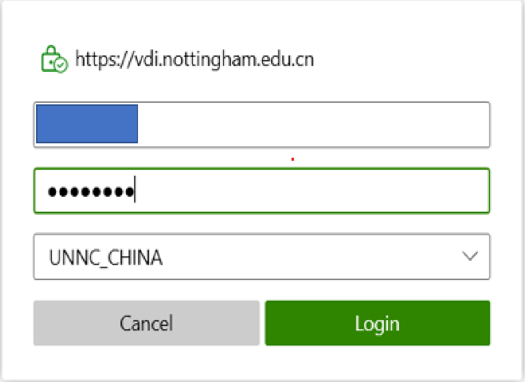
User Account Control

- After Vista, administrator users do not use an administrative access token by default
- Users have two tokens, one heavily restricted and used by default
- A prompt allows a user to spawn a process with the other token, or switch a process' token

Domains

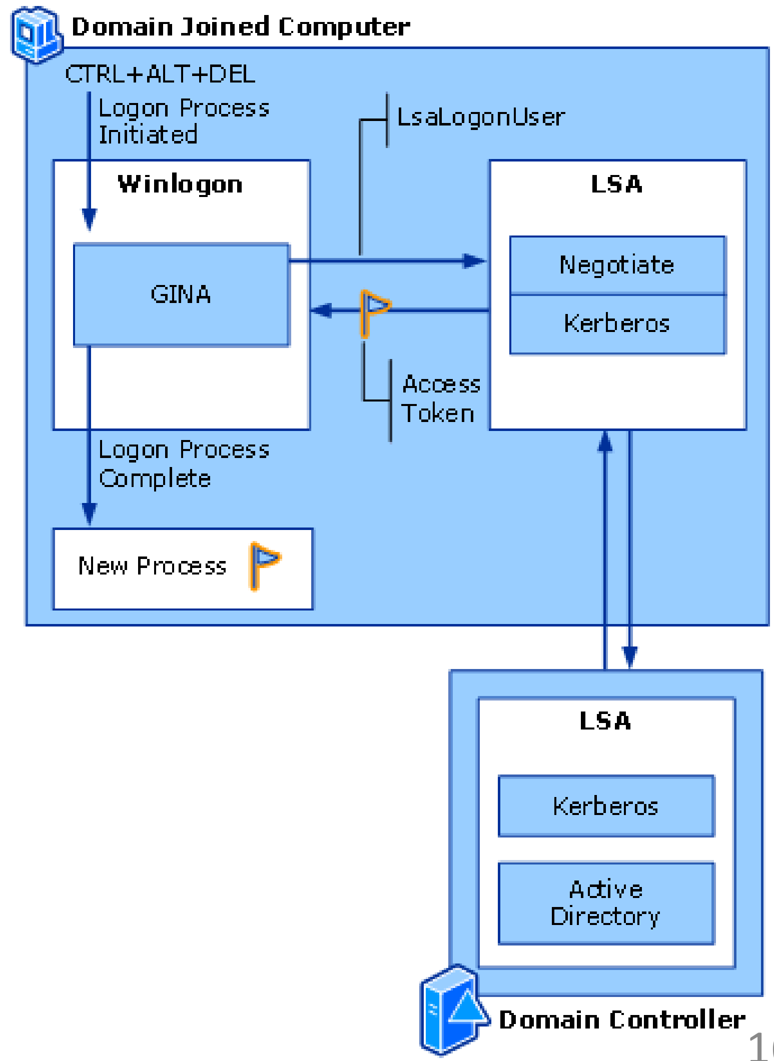
- Domain
  - A group of machines, sharing a common user account database and security policies
- Single sign-on for network resources
- Centralised security administration
- Domain Controller (DC)
  - Handles user accounts and access control





Domain Logon

- Ctrl+Alt+Delete initiates a login prompt using Graphical Identification and Authentication (GINA)
- Collected credentials are passed to the Local Security Authority (LSA)
- The LSA uses Kerberos to check the credentials against the Active Directory Domain Controller database
- Checks of a user are performed on the remote LSA
- Successful login provides an access token, which is used to spawn a shell (explorer.exe)



Summary

- Windows Security
  - Permissions
  - Access Tokens
  - Authentication
- Kerberos

Gollmann
Chapter 8, 15.4